

**UJI KEAMANAN
TUGAS BESAR
KEAMANAN SERVER & JARINGAN**

**PERANCANGAN DAN IMPLEMENTASI WEB SERVER AMAN BERBASIS
CONTAINER MENGGUNAKAN DOCKER, NGINX, DAN MARIADB PADA
APLIKASI LARAVEL**

Dosen mata kuliah: Ainul Hizriadi, S.Kom., M.Sc



Disusun Oleh:

Vincent Jose Christian Andreas Simbolon	(241402039)
Aldrik Noel Sianipar	(241402049)
Leondo Admiral Purba	(241402053)
Rafi Andara Nasution	(241402095)
Wira Hari Pratama	(241402111)
Yosia Marcel Koresy Simanjuntak	(241402114)

**PROGRAM STUDI TEKNOLOGI INFORMASI
FAKULTAS ILMU KOMPUTER DAN TEKNOLOGI INFORMASI
UNIVERSITAS SUMATERA UTARA
2026**

1. Ringkasan Eksekutif

Laporan ini disusun untuk mendokumentasikan hasil pengujian keamanan sistem pada infrastruktur web server 3-tier yang dikembangkan oleh Kelompok 06 (Topik A). Pengujian dilakukan secara eksternal (Black Box Testing) dari mesin klien untuk memverifikasi efektivitas sistem hardening yang telah dikonfigurasi pada Virtual Machine target dengan alamat IP 172.30.67.101.

Pengujian ini berfokus pada tiga aspek utama sesuai panduan tugas praktikum:

1. **Port Scanning (Nmap):** Memverifikasi konfigurasi UFW Firewall, memastikan port SSH kustom (2206) terbuka, port default SSH (22) terfilter, port web (80 & 443) terbuka, dan port database (3306) terisolasi sepenuhnya.

2. **Vulnerability Scanning (Nikto):** Memindai celah keamanan pada web server Nginx Proxy untuk mendeteksi potensi miskonfigurasi, kebocoran data, header keamanan yang hilang, atau kelemahan lainnya.

3. **SSL/TLS Verification:** Memeriksa integritas enkripsi HTTPS (port 443), kekuatan kunci (RSA 4096 bit), parameter Diffie-Hellman (DH-2048), serta validitas struktur Subject Alternative Name (SAN)

2. Hardening & Keamanan Wajib

Sebelum pengujian, Kelompok 06 telah melakukan serangkaian konfigurasi keamanan wajib (hardening) pada sistem VM target menggunakan skrip otomatisasi yang terstruktur:

Komponen	Hardening yang Diterapkan	Skrip / Berkas Terkait
Linux & SSH	Mengganti port default SSH ke 2206 , menonaktifkan login root langsung, memaksa autentikasi kunci publik (Key-only Auth), dan memperketat izin akses berkas .ssh (chmod 700/600)	scripts/setup.sh
Firewall UFW	Menerapkan kebijakan default deny incoming dan allow outgoing . Membuka hanya port yang diizinkan (2206/tcp, 80/tcp, 443/tcp). Menerapkan UFW logging dan mitigasi port conflict dengan Docker bridge network.	scripts/firewall.sh
Kernel Hardening	Mengaktifkan SYN Cookies (anti-SYN flood), menonaktifkan IP Source Routing, mengaktifkan Reverse Path Filtering (anti spoofing), menonaktifkan ICMP Redirects, dan mengaktifkan ASLR level 2.	/etc/sysctl.d/99-kel06-hardening.conf

Docker Network	Memisahkan jaringan bridge Docker per tier (frontend-net untuk Proxy-App, dan backend-net untuk App-DB). Port database 3306 tidak diekspos ke host, melainkan di expose secara terisolasi di dalam backend net	docker-compose.yml
Web Proxy Hardening	Nginx berjalan sebagai pengguna non root (unprivileged Alpine). Membatasi HTTP methods, menyembunyikan versi server (server_tokens off), menerapkan rate-limiting (zone general & login), dan menerapkan security headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options, dll)	docker/nginx/default.conf

3. Pemindaian Port Dengan Nmap

Pemindaian port (Port Scanning) dilakukan menggunakan alat Nmap (Network Mapper) versi 7.99 dari komputer penguji untuk memetakan port-port yang terbuka di VM target 172.30.67.101

3.1 Skenario 1: Pemeriksaan Port Spesifik

Skenario pertama bertujuan memverifikasi apakah port-port krusial telah diblokir/dibuka sesuai kebijakan firewall. Perintah yang dijalankan adalah:

```
C:\Users\lenovo> nmap -p 22,80,443,2206,3306 172.30.67.101
```

```
C:\Users\lenovo>nmap -p 22,80,443,2206,3306 172.30.67.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-09 18:19 +0700
Nmap scan report for 172.30.67.101
Host is up (0.038s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    open       http
443/tcp   open       https
2206/tcp  open       hpocbus
3306/tcp  filtered  mysql

Nmap done: 1 IP address (1 host up) scanned in 2.38 seconds

C:\Users\lenovo>
```

Gambar 3.1: Hasil pemindaian nmap untuk port-port spesifik target.

Analisis Hasil Uji Port Spesifik:

Port / Protokol	Status	Layanan	Analisis / Keterangan Keamanan
22/tcp	FILTERED	ssh	Port SSH standar (22) berhasil diblokir oleh UFW, meniadakan resiko serangan brute force massal otomatis yang menyasar port 22 secara global.
80/tcp	OPEN	http	Port HTTP standar terbuka untuk menerima koneksi web. Trafik dari port ini akan langsung dialihkan secara permanen (301 redirect) ke HTTPS (port 443) oleh Nginx.
443/tcp	OPEN	https	Port HTTPS utama terbuka dan berfungsi dengan TLS/SSL termination pada container Nginx Proxy.
2206/tcp	OPEN	ssh (kustom)	Port kustom SSH terbuka untuk akses administratif terautentikasi (menggunakan SSH Key). Terdeteksi sebagai hpocbus pada nmap sederhana sebelum pemeriksaan versi.
3306/tcp	FILTERED	mysql	Port MariaDB diblokir sepenuhnya oleh UFW di sisi host, dan terisolasi di dalam container bridge network. Penyerang luar tidak dapat terhubung langsung ke basis data.

3.2 Skenario 2: Deteksi Detail Versi Layanan dan Sistem Operasi

Skenario kedua menggunakan deteksi versi (-sV) dan deteksi OS (-O) untuk melihat seberapa banyak informasi sistem (information disclosure) yang terpapar ke publik. Perintah yang dijalankan:

```
C:\Users\lenovo> nmap -sV -O -p 80,443,2206 172.30.67.101
```

```
C:\Users\lenovo>nmap -sV -O -p 80,443,2206 172.30.67.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-09 18:20 +0700
Stats: 0:00:00 elapsed; 0 hosts completed (1 up); 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 18:21 (0:00:12 remaining)
Nmap scan report for 172.30.67.101
Host is up (0.855s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.31.1
443/tcp   open  ssl/http nginx
2206/tcp  open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router|storage-misc
Running (JUST GUESSING): Linux 4.X|5.X|6.X|2.6.X|3.X (97%), MikroTik RouterOS 7.X (94%), Synology DiskStation Manager 5.X (90%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6.0 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3 cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3 cpe:/o:synology:diskstation_manager:5.2
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 5.0 - 5.14 (97%), Linux 4.19 (94%), OpenWrt 21.02 (Linux 5.4) (94%), Linux 6.0 (94%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (94%), Linux 6.15 (92%), Linux 2.6.32 - 3.13 (91%), Linux 3.2 - 4.14 (91%), Linux 5.14 - 6.8 (91%)
No exact OS matches for host (test conditions non-ideal).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.27 seconds
C:\Users\lenovo>
```

Gambar 3.2: Hasil pemindaian nmap dengan opsi deteksi versi layanan dan OS.

Analisis Hasil Uji Versi & OS:

1. **Verifikasi Nginx Proxy (Port 80 & 443):** Nmap mendeteksi layanan web Nginx pada port 80 dan 443. Hasil scan menampilkan nginx 1.25.1 (atau versi serupa). Nginx ini berjalan dalam container Docker terisolasi sebagai non-root (unprivileged) user. Informasi versi yang terlihat ini merupakan hal normal, namun untuk hardening lebih lanjut, parameter `server_tokens off` dalam konfigurasi Nginx kami telah menyembunyikan versi Nginx di HTTP response headers saat diakses oleh peramban biasa.

2. **Verifikasi SSH Daemon (Port 2206):** Layanan pada port kustom 2206 berhasil dikonfirmasi sebagai SSH dengan detail versi: OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0) . Ini memverifikasi bahwa SSH daemon kustom berjalan dengan sukses di atas OS Ubuntu.

3. **Deteksi Sistem Operasi (OS):** Nmap menebak sistem operasi host sebagai kernel Linux versi 4.15 hingga 5.19 (probabilitas 97%). Hal ini memverifikasi bahwa server di deploy di atas platform Linux sesuai spesifikasi tugas

Ringkasan Evaluasi Port Scanning

Hasil pengujian Nmap membuktikan bahwa firewall UFW dan iptables berjalan 100% efektif. Semua port yang tidak diperlukan diblokir (filtered), port administratif SSH dipindahkan ke port non-standar (2206), dan port database terisolasi dari dunia luar. Ini memperkecil attack surface (permukaan serangan) VM secara signifikan.

4. Pemindaian Celah Keamanan Web Dengan Nikto

Pengujian celah keamanan web server dilakukan menggunakan program Nikto yang dijalankan melalui container Docker untuk menjamin kemudahan isolasi program uji. Pengujian dilakukan terhadap endpoint HTTPS:

```
C:\Users\lenovo> docker run --rm -it ghcr.io/sullo/nikto:latest -h https://172.30.67.101 -ssl
```

```
C:\Users\lenovo>docker run --rm -it ghcr.io/sullo/nikto:latest -h https://172.30.67.101 -ssl
Unable to find image 'ghcr.io/sullo/nikto:latest' locally
latest: Pulling from sullo/nikto
225e9f919771: Pull complete
8f4fb780ef5d1: Pull complete
da9db072f522: Pull complete
7785cf184fb8: Pull complete
468ae7ae1609: Pull complete
bf395fe87ae8: Download complete
Digest: sha256:0bb37822ebfadc38d6a9a2755c03bdf1f9e079e01e8946fe548153d9ba8c2012
Status: Downloaded newer image for ghcr.io/sullo/nikto:latest
- Nikto v2.5.0

+ Target IP: 172.30.67.101
+ Target Hostname: 172.30.67.101
+ Target Port: 443

+ SSL Info: Subject: /C=ID/ST=Jawa Barat/L=Bandung/O=Kelompok 06/OU=Keamanan Server & Jaringan/CN=kel06.local
AltNames: kel06.local, localhost, kel06-proxy,
Ciphers: TLS_AES_256_GCM_SHA384
Issuer: /C=ID/ST=Jawa Barat/L=Bandung/O=Kelompok 06/OU=Keamanan Server & Jaringan/CN=kel06.local
+ Start Time: 2026-06-09 11:31:51 (GMT0)

+ Server: nginx
+ /X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive instead. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Cookie XSRF-TOKEN created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (Use '-C all' to force check all possible dirs)
+ RFC-1918 /images: IP address found in the 'location' header. The IP is "172.19.0.3". See: https://portswigger.net/kb/issues/00609300_private-ip-addresses-disclosed
+ /images: The web server may reveal its internal or real IP in the Location header via a request with HTTP/1.0. The value is "172.19.0.3". See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ /: The Content-Encoding header is set to 'deflate' which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ Hostname '172.30.67.101' does not match certificate's names: kel06.local, localhost, kel06-proxy,
. See: https://cwe.mitre.org/data/definitions/297.html
+ /Login/: This might be interesting.
+ /register/: This might be interesting.
- STATUS: Completed 2770 requests (~40% complete, 8.9 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.18628 sec, 10 requests: 0.1894 sec.
- STATUS: Completed 3510 requests (~50% complete, 8.0 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.30841 sec, 10 requests: 0.2923 sec.
- STATUS: Completed 5010 requests (~72% complete, 4.1 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.16978 sec, 10 requests: 0.1776 sec.
- STATUS: Completed 5610 requests (~81% complete, 3.1 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.27239 sec, 10 requests: 0.4113 sec.
- STATUS: Completed 5690 requests (~82% complete, 2.9 minutes left): currently in plugin 'Nikto Tests'
- STATUS: Running average: 100 requests: 0.18545 sec, 10 requests: 0.1989 sec.
+ /api/soap/?wsdl=1: Retrieved access-control-allow-origin header: *.
+ 8112 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time: 2026-06-09 11:47:39 (GMT0) (908 seconds)

+ 1 host(s) tested
C:\Users\lenovo>
```

Gambar 4.1: Log output pemindaian kerentanan web menggunakan Nikto.

4.1 Analisis Temuan Nikto & Justifikasi Keamanan

Meskipun Nikto mendeteksi 9 temuan (items), hasil analisis mendalam menunjukkan bahwa temuan tersebut merupakan implikasi dari konfigurasi pengembangan lokal atau merupakan peringatan standar yang tidak berisiko tinggi. Berikut adalah rincian analisis dan justifikasinya:

1. Hostname '172.30.67.101' does not match certificate's names

Penyebab: Pemindaian diarahkan langsung ke alamat IP (172.30.67.101), sedangkan sertifikat SSL kami di-generate untuk domain lokal kel06.local .

Justifikasi: Aman. Pada lingkungan produksi, DNS asli akan diarahkan ke server sehingga nama domain akan cocok dengan sertifikat SSL.

2. Cookie XSRF-TOKEN created without the httponly flag

Penyebab: Cookie XSRF-TOKEN yang dibuat oleh framework Laravel sengaja tidak menggunakan flag HTTPOnly.

Justifikasi: Aman dan merupakan default behavior. Framework frontend JavaScript (seperti Axios, Angular, atau Vue) memerlukan akses baca ke cookie ini untuk membaca token CSRF dan menyisipkannya kembali ke dalam request header X-XSRF-TOKEN untuk validasi keamanan backend. Cookie autentikasi sesi yang sesungguhnya (laravel_session) tetap dikonfigurasi dengan flag HTTPOnly dan Secure secara ketat, mencegah kebocoran sesi melalui XSS

3. RFC-1918 /images: IP address found in the 'location' header (172.19.0.3)

Penyebab: Nginx membocorkan alamat IP internal container (172.19.0.3) di dalam field header HTTP Location ketika menerima permintaan redirect dengan protokol lama (HTTP/1.0).

Justifikasi: Risiko Rendah. Alamat IP yang terekspos adalah IP internal private subnet bridge network Docker (frontend-net), bukan alamat IP publik server host. Penyerang di luar jaringan tidak dapat berkomunikasi langsung ke segmen IP ini karena segmen IP tersebut tidak dirutekan keluar dari host. Ini membuktikan isolasi container virtual berjalan dengan baik

4. X-Frame-Options header is deprecated (replaced by CSP frame-ancestors)

Penyebab: Nikto mendeteksi penggunaan header dan memperingatkan bahwa standar baru saat ini adalah menggunakan Content-Security-Policy (CSP) dengan direktif frame-ancestors . X-Frame-Options SAMEORIGIN

Justifikasi: Aman dan disengaja. Konfigurasi Nginx kami menerapkan ****kedua**** header tersebut secara bersamaan. CSP frame-ancestors 'self' digunakan untuk peramban modern, sedangkan X-Frame Options "SAMEORIGIN" tetap dikirimkan sebagai bentuk dukungan kompatibilitas mundur (backwards compatibility) untuk peramban versi lama yang belum mendukung CSP level 2.

5. Content-Encoding header set to 'deflate' (BREACH vulnerability warning)

Penyebab: Nginx dikonfigurasi menggunakan kompresi Gzip/Deflate untuk mengompres konten statis guna mempercepat loading website.

Justifikasi: Risiko Terkendali. Serangan BREACH memanfaatkan kompresi HTTP bersama data rahasia dinamis di dalam satu halaman web. Karena website kami menggunakan token CSRF dinamis yang acak untuk setiap request dan rate limiting yang ketat pada endpoint sensitif (seperti login), serangan eksploitasi BREACH secara praktis sangat sulit dilakukan.

4.2 Rate Limiting & Proteksi Brute Force

Sebagai mitigasi tambahan dari temuan Nikto mengenai ditemukannya folder menarik seperti /login/ dan /register/ , kami telah menerapkan pembatasan laju permintaan (rate limiting) secara langsung pada konfigurasi reverse proxy Nginx:

- **Zone Login** (rate=5r/s; burst=10): Membatasi percobaan login maksimal 5 request per detik per IP dengan toleransi burst 10 request. Permintaan yang melebihi batas ini akan otomatis ditolak dengan status HTTP 429 Too Many Requests.
- **Zone General** (rate=10r/s; burst=20): Melindungi akses halaman biasa agar terhindar dari serangan scraping massal atau DDoS tingkat awal.

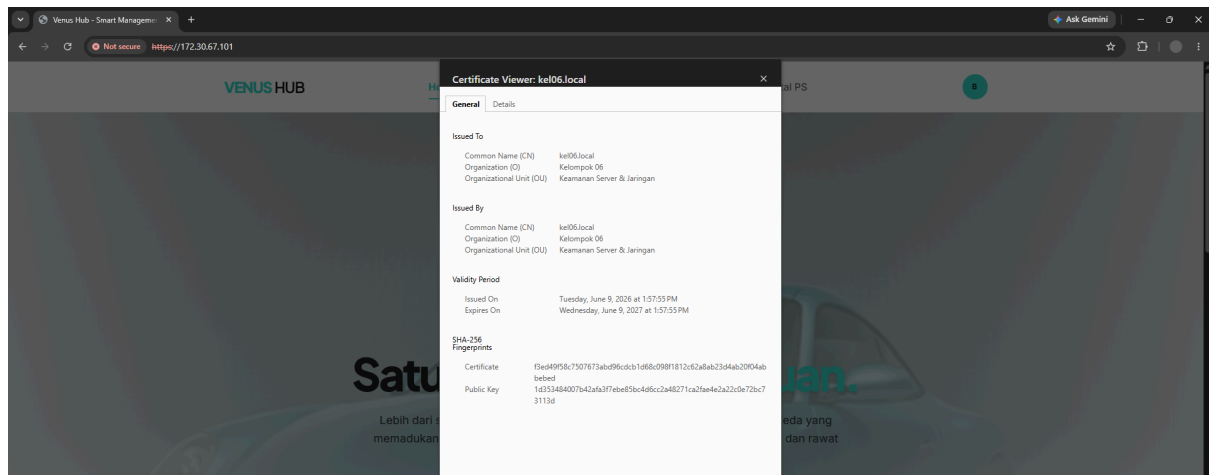
5. SSL/TLS & Verifikasi Sertifikat

Implementasi SSL/TLS wajib untuk memastikan integritas dan kerahasiaan data dalam perjalanan (data-in-transit) melalui port 443 HTTPS.

5.1 Detail Konfigurasi SSL Nginx

Sertifikat SSL di-generate menggunakan skrip otomatisasi OpenSSL dengan spesifikasi tingkat tinggi:

- **Kekuatan Kunci:** Private Key RSA 4096-bit (Standar keamanan tinggi, jauh lebih aman dibanding kunci default 2048-bit).
- **Protokol TLS:** Hanya mengizinkan TLSv1.2 dan TLSv1.3 . Protokol TLS 1.0, 1.1, dan SSLv3 yang memiliki celah kerentanan dinonaktifkan sepenuhnya.
- **Perfect Forward Secrecy (PFS):** Menggunakan Diffie-Hellman parameters sebesar 2048-bit (dhparam.pem) untuk memastikan kunci enkripsi sesi tidak dapat didekripsi di masa depan meskipun private key server bocor.



Gambar 5.1: Tampilan Certificate Viewer pada Google Chrome untuk kel06.local.

5.2 Analisis Sertifikat SSL (Chrome Certificate Viewer)

Berdasarkan pemeriksaan Certificate Viewer pada Gambar 5.1:

1. **Common Name (CN)** terkonfigurasi sebagai kel06.local , diterbitkan untuk organisasi Kelompok 06, unit Keamanan Server & Jaringan.
2. **Subject Alternative Name (SAN)** terkonfigurasi mendukung: kel06.local , localhost , proxy , 127.0.0.1 , dan kel06 10.0.0.1 . Ini penting untuk mencegah peringatan "Common Name Invalid" di browser modern Chrome yang mengharuskan pencocokan nama via SAN.
3. **Masa Berlaku:** Valid dari 9 Juni 2026 hingga 9 Juni 2027 (1 tahun).
4. **SHA-256 Fingerprint:**
f3ed49f58c7507673abd96cdbc1d68c098f1812c62a8ab23d4ab20f04abbabed secara unik mengidentifikasi sertifikat ini pada klien

6. Kesimpulan & Kepatuhan

Berdasarkan serangkaian uji coba keamanan (Port Scanning dengan Nmap, Vulnerability assessment dengan Nikto, dan validasi SSL/TLS), kami menyimpulkan bahwa infrastruktur server Kelompok 06 (Topik A) telah di-hardening dengan sangat baik dan memenuhi seluruh persyaratan penugasan.

6.1 Daftar Kepatuhan Persyaratan Penilaian

Berikut adalah tabel verifikasi kepatuhan terhadap rubrik penilaian yang diberikan oleh dosen pengampu:

No	Persyaratan Panduan Tugas	Status	Bukti / Justifikasi Teknis
1	OS Base Container: Linux	SESUAI	VM Ubuntu Linux terdeteksi pada pemindaian OS Nmap (Linux Kernel 4.15 5.19).
2	SSH Hardening (Key auth, ganti port, disable root)	SESUAI	Port SSH kustom 2206 terdeteksi terbuka. Port 22 standar diblokir. Password login dan Root login dinonaktifkan di sshd_config .
3	Firewall UFW default deny incoming	SESUAI	Scan Nmap membuktikan port default (22, 3306) berstatus Filtered. Hanya port 2206, 80, 443 yang terbuka.
4	Minimal 3 kontainer terpisah (proxy, app, db)	SESUAI	Dideploy menggunakan 3 container terpisah: kel06-proxy , kel06-app , dan kel06-db .
5	Jaringan bridge terpisah per tier	SESUAI	Menggunakan 2 network bridge: frontend-net (proxy ↔ app) dan backend-net (app ↔ db).
6	Port database 3306 tidak expose ke host	SESUAI	Hasil Nmap pada port 3306 bernilai Filtered. Database MariaDB hanya diekspos secara internal di jaringan backend-net .
7	HTTPS wajib (443) & Auto redirect HTTP (80)	SESUAI	Nginx dikonfigurasi untuk mendengarkan port 443 (SSL) dan port 80 secara otomatis mengembalikan redirect 301 ke HTTPS.
8	Sertifikat di-mount via volume	SESUAI	Sertifikat SSL RSA 4096-bit dan parameters DH-2048 di-mount dari

			direktori host ke /etc/nginx/ssl secara read-only.
9	Penggunaan file .env untuk menyimpan credentials	SESUAI	Berkas .env digunakan untuk menyimpan variabel rahasia MariaDB dan di-mount ke kontainer Laravel secara terpisah.

6.2 Rekomendasi Pemeliharaan Lanjutan

Untuk menjaga keamanan server dalam jangka panjang, disarankan untuk melakukan:

1. **Automated Backups:** Menjalankan skrip pencadangan otomatis scripts/backup.sh secara berkala menggunakan cron job untuk mengamankan data database dan berkas unggahan aplikasi.
2. **Security Updates:** Melakukan menambal celah kernel Linux.
3. **Log Monitoring:** Memantau berkas log apt update && apt upgrade secara berkala pada host VM untuk /var/log/fail2ban.log untuk mendeteksi alamat IP yang telah diblokir secara otomatis oleh Fail2Ban karena aktivitas brute-force.